



中华人民共和国国家标准

GB/T XXXXX—XXXX

信息安全技术 数据安全风险评估方法

Information security technology — Risk assessment method for data security

（征求意见稿）

（本稿完成时间：2023 年 8 月 20 日）

在提交反馈意见时，请将您知道的相关专利连同支持性文件一并附上。

XXXX - XX - XX 发布

XXXX - XX - XX 实施

国家市场监督管理总局
国家标准化管理委员会 发布

目 次

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 缩略语 2

5 通则 3

 5.1 概述 3

 5.2 风险要素关系 3

 5.3 风险分析原理 4

 5.4 评估适用情形 4

 5.5 评估实施流程 5

 5.6 评估内容框架 6

 5.7 评估手段 7

6 数据安全风险评估准备 7

 6.1 确定评估目标 7

 6.2 确定评估范围 7

 6.3 组建评估团队 8

 6.4 开展前期准备 8

 6.5 制定评估方案 9

7 信息调研 9

 7.1 数据处理者调研 9

 7.2 业务和信息系统调研 9

 7.3 数据资产调研 10

 7.4 数据处理活动调研 10

 7.5 安全防护措施识别 11

8 风险识别 11

 8.1 通则 11

 8.2 已开展测评工作结论分析 11

 8.3 数据安全 管理 12

 8.4 数据处理活动安全 12

 8.5 数据安全 技术 13

8.6 个人信息保护 13

9 风险分析与评价 13

9.1 通则13

9.2 数据安全风险分析 13

9.3 数据安全风险评价 16

9.4 数据安全风险清单 17

10 评估总结 17

10.1 编制评估报告 17

10.2 风险处置建议 18

10.3 残余风险分析 18

附 录 A （规范性） 典型数据安全风险类别 19

附 录 B （规范性） 数据安全风险量化分析与评价方法 21

附 录 C （资料性） 数据安全风险评估报告模板 22

参 考 文 献 25

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由全国信息安全标准化技术委员会（SAC/TC 260）提出并归口。

本文件起草单位：中国电子技术标准化研究院、国家信息技术安全研究中心、国家计算机网络应急技术处理协调中心、国家工业信息安全发展研究中心、阿里巴巴（北京）软件服务有限公司、中国信息安全测评中心、国家信息中心、中国科学院信息工程研究所、公安部第三研究所、北京市政务信息安全保障中心、北京快手科技有限公司、蚂蚁科技集团股份有限公司、中国网络安全审查技术与认证中心、中国科学技术大学、中国科学院软件研究所、华为技术有限公司等。

本文件主要起草人：姚相振、胡影、张宇光、上官晓丽、杨韬、林星辰、任英杰、朱雪峰、李敏、孙勇、都婧、马英、张妍、苏艳芳、李媛、落红卫、白晓媛、陈世翔、左晓栋、张立武、邵萌等。

信息安全技术 数据安全风险评估方法

1 范围

本文件给出了数据安全风险评估的基本概念、要素关系、分析原理、实施流程、评估内容、分析与评价方法等，明确了数据安全风险评估各阶段的实施要点和工作方法。

本文件适用于指导数据处理者、第三方评估机构开展数据安全风险评估，也可供有关主管监管部门实施数据安全检查评估时参考。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 35273—2020 信息安全技术 个人信息安全规范

GB/T 25069—2022 信息安全技术 术语

GB/T 20984—2022 信息安全技术 信息安全风险评估方法

GB/T AAAA—XXXX 信息安全技术 数据分类分级规则

TC260-PG-20231A 网络安全标准实践指南——网络数据安全风险评估实施指引

3 术语和定义

GB/T 25069-2022界定的以及下列术语和定义适用于本文件。

3.1

数据 data

任何以电子或者其他方式对信息的记录。

3.2

数据安全 data security

通过采取必要措施，确保数据处于有效保护和合法利用的状态，以及具备保障持续安全状态的能力。

3.3

数据处理活动 data processing activities

数据收集、存储、使用、加工、传输、提供、公开、删除等活动。

3.4

合理性 rationality

数据处理遵守法律、行政法规要求，尊重社会公德和伦理道德，符合网络安全和数据安全常识道理。

3.5

数据安全风险 data security risk

数据安全事件的发生可能性及其对国家安全、公共利益或者组织、个人合法权益造成的影响。

3.6

数据安全风险评估 data security risk assessment

对数据和数据处理活动安全进行信息调研、风险识别、风险分析和风险评价的整个过程。

3.7

业务 business

组织为实现某项发展规划而开展的运营活动。

注：该活动具有明确的目标，并延续一段时间。

[来源：GB/T 20984-2022, 3.1.4]

3.8

风险源 risk source

可能导致危害数据的保密性、完整性、可用性和数据处理合理性等事件的威胁、脆弱性、问题、隐患等，也称“风险隐患”。

注：风险隐患，既包括安全威胁利用脆弱性可能导致数据安全事件的风险隐患，也包括数据处理活动不合理操作可能造成违法违规处理事件的风险隐患。

3.9

自评估 self-assessment

由数据处理者自身发起，组成机构内部评估小组或委托第三方评估机构，依据有关政策法规与标准，对评估对象的数据安全风险进行评估的活动。

[来源：GB/T 20984-2022, 3.1.8，有修改]

3.10

检查评估 inspection and assessment

由数据处理者的上级主管部门、业务主管部门或国家有关主管（监管）部门发起的，依据有关政策法规与标准，对评估对象的数据安全风险进行的评估活动。

[来源：GB/T 20984-2022, 3.1.9，有修改]

4 缩略语

下列缩略语适用于本文件。

API: 应用程序编程接口 (Application Programming Interface)

App: 移动互联网应用程序 (Mobile Internet Application)

SDK: 软件开发工具包 (Software Development Kit)

5 通则

5.1 概述

数据安全风险评估, 主要围绕数据和数据处理活动, 聚焦可能影响数据的保密性、完整性、可用性和数据处理合理性的安全风险, 掌握数据安全总体状况, 发现数据安全隐患, 提出数据安全管理和技术防护措施建议, 提升数据安全防攻击、防破坏、防窃取、防泄露、防滥用能力。首先通过信息调研识别数据处理器、业务和信息系统、数据资产、数据处理活动、安全措施等相关要素, 然后从数据安全管理和数据处理活动、数据安全技术和个人信息保护等方面识别风险隐患, 最后梳理风险源清单, 分析数据安全风险、视情评价风险, 并给出整改建议。

5.2 风险要素关系

数据安全风险评估涉及数据、数据处理活动、业务、信息系统、安全措施、风险源等基本要素, 要素间关系如图1所示。

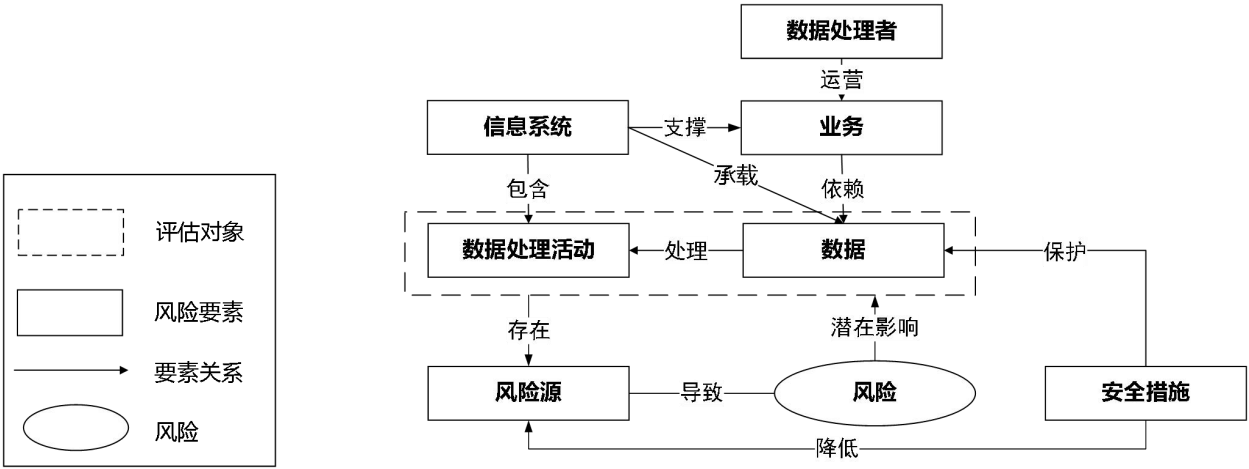
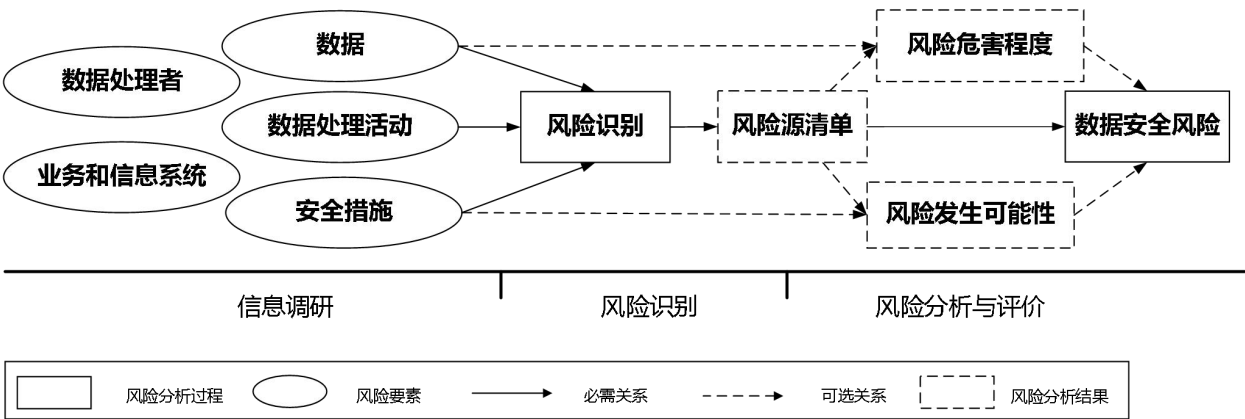


图 1 数据安全风险评估要素关系

- 开展数据安全风险评估应充分考虑要素间关系。各要素关系说明如下：
- a) 数据是核心要素, 具有数据价值等属性, 数据价值将影响数据安全风险的危害程度。
 - b) 数据和数据处理活动是数据安全风险评估的评估对象。
 - c) 数据处理器运营业务, 业务依赖数据实现。
 - d) 业务需要依托信息系统的支撑, 可能涉及一个或多个信息系统。
 - e) 信息系统包含多个数据处理活动, 信息系统是数据的载体。
 - f) 数据在流转过程中涉及一个或多个数据处理活动, 数据处理活动应遵循数据安全法律法规要求。
 - g) 安全措施用于保护数据安全, 能降低数据安全风险源发生的可能性。
 - h) 数据和数据处理活动作为评估对象, 可能存在风险源, 风险源可能引发数据安全风险, 数据安全风险将对数据和数据处理活动有潜在影响。

5.3 风险分析原理

数据安全风险评估，主要围绕数据处理者的数据和数据处理活动，对可能影响数据保密性、完整性、可用性和数据处理合理性的安全风险进行分析和评价。数据安全风险评估原理如图2所示。



数据安全风险评估主要包括信息调研、风险识别、风险分析与评价等，数据安全风险评估的主要内容包

- a) **信息调研**：对可能影响数据安全风险的要素的情况调研，包括数据处理者、业务和信息系统、数据资产、数据处理活动、数据安全防护措施。掌握数据处理者、业务和信息系统基本情况，梳理涉及的数据资产和数据处理活动，了解采取的数据安全防护措施情况，掌握被评估对象或同行业相关数据安全事件历史发生情况。
- b) **风险识别**：基于信息调研情况，从数据安全、数据处理活动安全、数据安全技术、个人信息保护等方面进行数据安全风险识别，识别评估对象现有安全措施完备性并对其有效性进行验证，识别可能存在的风险源。
- c) **风险分析与评价**：通过分析风险类型、风险危害程度和可能性，评价风险等级。

注：TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》第7章综合分析，与本文件第9章风险分析和评价兼容，本文件给出了更详细的风险分析和评价方法。

- 1) 数据安全风险分析，包括数据安全风险归类（9.2.2）、风险危害程度分析（9.2.3）、风险发生可能性分析（9.2.4）。
- 2) 风险归类分析，结合风险源可能引发的风险类型，对风险源进行归类。
- 3) 风险危害程度分析，从数据价值、数据重要性、风险源危害程度等方面，综合评价风险可能对国家安全、公共利益或者个人、组织合法权益造成的危害程度。
- 4) 风险发生可能性，从风险源发生频率、安全措施有效性和完备性、风险源关联性等方面，综合评价风险发生的可能性。
- 5) 风险评价过程，一般根据风险危害程度和风险发生可能性评价数据安全风险，得到数据安全风险级别，梳理形成数据安全风险清单。

在数据安全分析和评价中，数据安全风险危害程度分析、风险发生可能性分析、数据安全风险评价等步骤可选，如不执行上述步骤，可结合风险源清单和风险归类分析结果得到数据安全风险清单。

5.4 评估适用情形

适用于以下情形之一的数据处理者，可结合实际情况开展数据安全风险评估：

- a) 重要数据处理者、关键信息基础设施运营者、处理 100 万人以上个人信息的个人信息处理者、大型互联网平台运营者、赴境外上市的数据处理者、党政机关、网络安全等级保护三级及以上运营者，应每年开展一次数据安全风险评估。
- b) 数据处理者在重要数据共享、交易、委托处理或向境外提供前，应开展数据安全风险评估。
- c) 数据处理者开展高风险数据处理活动前，宜开展数据安全风险评估，高风险数据处理活动包括但不限于：
 - 1) 重要数据和个人信息处理者合并、分立、解散、被宣告破产进行数据转移。
 - 2) 承载重要数据处理活动的信息系统发生架构调整、下线等重大变更。
 - 3) 数据处理者利用生物特征进行个人身份认证。
 - 4) 基于不同业务目的的数据汇聚融合。
 - 5) 委托处理、向他人提供未成年人、老年人数据。
 - 6) 新技术应用可能带来数据安全风险的。
 - 7) 法律法规或有关部门规定要评估的情形。
 - 8) 其他可能直接危害国家安全、公共利益或者大量个人、组织合法权益的数据处理活动。
- d) 对于已经评估过数据安全风险评估的数据处理活动，当数据范围、数据处理活动、环境、相关方等发生重大变更时，需重新开展数据安全风险评估。
- e) 重要系统上线前，可根据实际需要开展数据安全风险评估。
- f) 当被评估对象的政策环境、外部威胁环境、业务目标、安全目标等发生重大变化时，应重新开展风险评估。

5.5 评估实施流程

数据安全风险评估流程，主要包括评估准备、信息调研、风险识别、综合分析、评估总结五个阶段，如图 3 所示：

注：应依据 TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》3.3 进行数据安全风险评估、第三方评估及检查评估，与本文件给出的评估实施流程一致。

- a) 评估准备：是数据安全风险评估的初始预备阶段，在评估实施前应完成评估准备工作。形成调研表、数据安全风险评估方案等。
- b) 信息调研：主要用于识别数据处理者的基本情况，厘清其与业务和信息系统的关系，处理的数据和开展的数据处理活动情况，采取的数据安全防护措施。形成数据处理者基本情况、业务清单、信息系统清单、数据资产清单、数据处理活动清单、安全措施情况等，具备条件的，可绘制数据流图。
- c) 风险识别：针对各个评估对象，从数据安全、数据处理活动、数据安全技术、个人信息保护等方面，通过多种评估手段识别可能存在的数据安全风险隐患。形成文档查阅记录文档、人员访谈记录文档、安全核查记录文档、技术检测报告等。
- d) 风险分析与评价：在风险识别基础上开展风险分析，并视情对风险进行评价，最后提出整改建议。形成数据安全风险源清单、数据安全风险列表、整改建议等。
- e) 评估总结：编制数据安全风险评估报告，开展风险处置。



图 3 数据安全风险评估实施流程图

5.6 评估内容框架

数据安全风险评估，在信息调研基础上，围绕数据安全管理制度、数据处理活动安全、数据安全技术、个人信息保护等方面开展评估。评估内容框架如图 4 所示。评估项可参考第 8 章。

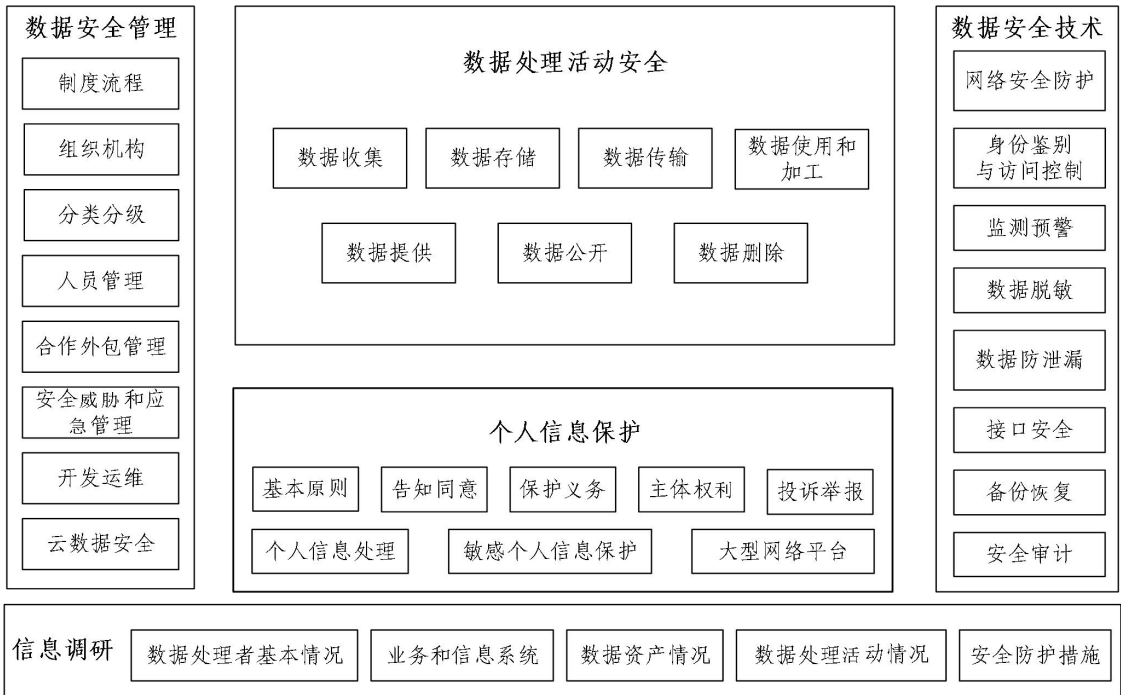


图 4 数据安全风险评估内容框架图

5.7 评估手段

开展数据安全风险评估时，综合采取下列手段进行评估：

- a) 人员访谈：对相关人员进行访谈，核查制度规章、防护措施、安全责任落实情况。
- b) 文档查验：查验安全管理制度、风险评估报告、等保测评报告等有关材料及制度落实情况的证明材料。
- c) 安全核查：核查网络环境、数据库和大数据平台等相关系统和设备安全策略、配置、防护措施情况。
- d) 技术测试：应用技术工具、渗透测试等手段查看数据资产情况、检测防护措施有效性。

6 数据安全风险评估准备

6.1 确定评估目标

数据安全风险评估的目标包括但不限于：

- a) 摸清数据种类、规模、分布等基本情况；
- b) 摸清数据处理活动的情况；
- c) 发现可能影响国家安全、公共利益或者个人、组织合法权益的数据安全问题和风险；
- d) 发现共享、交易、委托处理、向境外提供重要数据等处理活动的数据安全问题和风险；
- e) 促进完善数据安全保护措施，提升数据安全保护能力。

6.2 确定评估范围

根据工作需要和评估目标，确定数据安全风险评估的对象、范围和边界，明确评估涉及的数据资产、数据处理活动、业务和信息系统、人员和内外部组织等。数据安全风险评估聚焦数据和数据处理活动，

评估范围可以是某个单独的业务、信息系统、部门涉及的数据和数据处理活动，可以是组织全部数据和数据处理活动。

当选取组织全部数据和数据处理活动作为评估范围时，可根据需要采取“全面摸排、重点评估”的原则，按步骤确定评估范围：

a) 全面摸排被评估方的数据安全整体情况，摸清其数据资产、数据处理活动、数据分类分级等情况。

b) 结合数据分类分级选择重点评估对象，将涉及个人信息、重要数据、核心数据的所有数据处理活动，以及抽样选择的其他典型一般数据的处理活动作为重点评估对象开展评估。

c) 如果组织未开展数据分类分级工作，也可结合业务、信息系统的重要性和敏感性，选择核心业务或重要信息系统的数据和数据处理活动作为重点评估对象开展评估。

当选取某个单独的业务、信息系统、部门涉及的数据和数据处理活动进行评估时，可参考上述方法确定评估范围。可以选择重点评估对象，也可以将涉及的全部数据和数据处理活动纳入评估范围。

6.3 组建评估团队

数据处理者自行或委托第三方专业技术机构开展数据安全风险评估时，可组织业务、安全、法务、合规、运维、研发等相关部门参与实施，评估组长由数据安全负责人或授权代表担任，也可委托第三方专业技术机构实施。第三方机构在评估中获取的信息只能用于评估目的，未经授权不应泄露、出售或者非法向他人提供。

主管监管部门开展检查评估时，可根据评估范围、涉及的行业特征、专业需求，选择具备相关专业能力的评估人员组成评估队伍。评估队伍应提前完成风险评估文档、检测工具等各项准备工作，并签署保密协议。评估队伍在检查评估中获取的信息，只能用于检查任务目的和实施数据安全保护。被评估方应建立专项工作团队，成员一般包括数据安全负责人和安全、法务、合规、运维、研发、业务、数据、风险等部门相关人员。专项工作团队应按照要求做好人员、设备、技术保障等工作，配合开展风险评估。

6.4 开展前期准备

开展数据安全风险评估前期准备时，应根据评估目标、评估范围和调研情况，制定工作计划、确定评估依据、确定评估内容、建立评估文档：

- a) 制定工作计划。评估工作计划内容一般包括工作目的、工作要求、工作内容、工作流程、调研安排、评估总体进度安排等。开展检查评估时，主管监管部门指导评估团队按照工作要求制定评估工作计划。
- b) 确定评估依据。针对评估目标和范围确定评估依据，常见评估依据包括但不限于：
 - 1) 《网络安全法》《数据安全法》《个人信息保护法》等法律，有关行政法规、司法解释。
 - 2) 网信部门及主（监）管部门相关数据安全规章、规范性文件。
 - 3) 地方数据安全政策规定和监管要求。
 - 4) 数据安全相关国家标准、行业标准等。
 - 5) 开展自评估时，本单位数据安全制度规范可作为评估依据之一。
- c) 确定评估内容。结合评估目标、范围、依据，针对被评估方的实际情况，确定被评估方每个评估对象适用的评估内容：
 - 1) 数据处理者应针对数据处理活动、数据安全管理制度、数据安全技术等方面进行风险评估。
 - 2) 涉及处理个人信息的，应在1)的基础上，对个人信息保护开展风险评估。
 - 3) 开展评估工作过程中，可根据任务要求、评估重点、监管需要、评估依据等，进一步完善评估内容。

- d) 建立评估文档。针对评估目标、范围、依据和内容，准备风险评估调研表、技术测试工具等。在评估工作开展过程中，应对评估工作相关文件进行统一编号，并规范管理。

6.5 制定评估方案

评估团队编制数据安全风险评估工作方案并获得评估管理方的支持、认可，方案内容包括但不限于：

- a) 评估概述：包括评估目标、评估依据等内容；
- b) 评估范围：包括评估对象选择方法、评估对象描述、评估范围等；
- c) 评估内容和方法：包括评估内容、评估准则、评估方法等内容；
- d) 评估人员：包括评估团队的组织结构、负责人、成员、职责分工等内容；
- e) 实施计划：包括时间进度安排、人员安排等内容；
- f) 工作要求：包括评估工作要求、被评估方保障条件等内容，工作要求如严格依照评估内容及标准规范，规范评估行为，按照尽量不影响被评估方正常工作的原则，制定评估工作应急保障和风险规避措施，明确告知被评估方评估可能产生的风险，严守工作纪律和保密要求等；
- g) 测试方案：开展技术测试前应明确测试方案，包括采用的技术工具、测试内容、测试环境、应急措施等，测试方向应向被测方明示测试可能涉及的安全风险，双方就测试方案达成共识，检查评估时应提前向有关部门报备；

评估团队可邀请行业领域相关数据安全、网络安全专家对评估方案进行评议，重点审核方案内容、风险管控、保护措施、可操作性、技术可行性等，进一步修改完善评估方案后，组织实施风险评估工作。

7 信息调研

7.1 数据处理者调研

数据处理者的基本情况包括但不限于：

- a) 单位名称、组织机构代码、办公地址、法定代表人信息、人员规模、经营范围、数据安全负责人及其职务、联系方式等基本信息。
- b) 单位性质，例如党政机关、事业单位、企业、社会团体等。
- c) 是否属于特定类型数据处理者，例如政务数据处理者、大型网络平台运营者、关键信息基础设施运营者等。
- d) 所属行业领域。
- e) 业务运营地区，开展数据处理活动所在国家和地区等。
- f) 主要业务范围、业务规模等。
- g) 数据处理相关服务取得行政许可的情况。
- h) 被评估单位的资本组成和实际控制人情况。
- i) 是否境外上市或计划赴境外上市及境外资本参与情况，或以协议控制（VIE）架构等方式实质性境外上市。

7.2 业务和信息系统调研

业务和信息系统情况包括但不限于：

- a) 网络和信息系统基本情况，包括网络规模、拓扑结构、信息系统等情况和对外连接、运营维护等情况以及是否为关键信息基础设施等情况。
- b) 业务基本信息，包括业务描述、业务类型、服务对象、业务流程、用户规模、覆盖地域、相关部门等基本信息。

- c) 业务涉及个人信息、重要数据或核心数据处理情况。
- d) 业务为政务部门或境外用户提供服务情况。
- e) 信息系统、App 和小程序情况，包括系统功能、网络安全等级保护备案和测评结论、入口地址、系统连接关系、数据接口、App 及小程序名称和版本等。
- f) 数据中心和使用云平台情况。
- g) 接入的外部第三方产品、服务或 SDK 的情况，包括名称、版本、提供方、使用目的、合同协议等。

7.3 数据资产调研

梳理结构化数据资产（如数据库表等）和非结构化数据资产（如图表文件等），摸清数据底数，输出数据资产清单。涉及范围包括但不限于生产环境、测试环境、备份存储环境、云存储环境、个人工作终端、数据采集设备终端等收集和产生的数据。调研内容包括但不限于：

- a) 数据资产情况，包括数据资产类型、数据范围、数据规模、数据形态、数据存储分布、元数据等。
- b) 数据分类分级情况，包括数据分类分级规则、数据类别、数据级别、重要数据和核心数据目录情况等。
- c) 个人信息情况，包括个人信息种类、规模、敏感程度、数据来源、业务流转及与信息系统的对应关系等。
- d) 重要数据情况，包括重要数据种类、规模、行业领域、敏感程度、数据来源、业务流转及与信息系统的对应关系等。
- e) 核心数据情况，包括核心数据种类、规模、行业领域、敏感程度、数据来源、业务流转及与信息系统的对应关系等。
- f) 其他一般数据情况。

7.4 数据处理活动调研

针对评估对象和范围，梳理数据处理活动清单，验证或绘制数据流图。数据流图应描述数据流转各环节经过的相关方、信息系统，以及每个流动环节涉及的数据类型等。调研内容包括但不限于：

- a) 数据收集情况，如数据收集渠道、收集方式、数据范围、收集目的、收集频率、外部数据源、合同协议、相关系统，以及在被评估方外部公共场所安装图像采集、个人身份识别设备的情况等。
- b) 数据存储情况，如数据存储方式、数据中心、存储系统（如数据库、大数据平台、云存储、网盘、存储介质等）、外部存储机构、存储地点、存储期限、备份冗余策略等。
- c) 数据传输情况，如数据传输途径和方式（如互联网、VPN、物理专线等在线通道情况，采用介质等离线传输情况）、传输协议、内部数据共享、数据接口等。
- d) 数据使用和加工情况，如数据使用目的、方式、范围、场景、算法规则、相关系统和部门，数据清洗、转换、标注等加工情况，应用算法推荐技术提供互联网信息服务的情况，核心数据、重要数据或个人信息委托处理、共同处理的情况等。
- e) 数据提供情况，如数据提供（数据共享、数据交易，因合并、分立、解散、被宣告破产等原因需要转移数据等）的目的、方式、范围、数据接收方、合同协议，对外提供的个人信息和重要数据的种类、数量、范围、敏感程度、保存期限等。
- f) 数据公开情况，如数据公开的目的、方式、对象范围、受众数量、行业、组织、地域等。
- g) 数据删除情况，如数据删除情形、删除方式、数据归档、介质销毁等。
- h) 数据出境情况，是否存在个人信息或重要数据出境，如跨境业务、跨境办公、境外上市、使用

境外云服务或数据中心、国际交流合作等场景的数据出境情况。

7.5 安全防护措施识别

调研已有安全措施情况，包括但不限于：

- a) 已开展的等级保护测评、商用密码应用安全性评估、安全检测、风险评估、安全认证、合规审计情况，及发现问题的整改情况。
- b) 数据安全组织、人员及制度情况。
- c) 防火墙、入侵检测、入侵防御等网络安全设备及策略情况。
- d) 身份鉴别与访问控制情况。
- e) 网络安全漏洞管理及修复情况。
- f) VPN 等远程管理软件的用户及管理情况。
- g) 设备、系统及用户的账号口令管理情况。
- h) 加密、脱敏、去标识化等安全技术应用情况。
- i) 3 年内发生的网络和数据安全事件、攻击威胁情况。
 - 1) 事件名称、数据类型和数量、发生原因、级别、处置措施、整改措施等，重大事件需提供事件调查评估报告。
 - 2) 近 3 年发生的数据安全事件处置、记录、整改和上报情况。
 - 3) 实际环境中通过检测工具、监测系统、日志审计等发现的威胁。
 - 4) 近期公开发布的社会或特定行业威胁事件、威胁预警。
 - 5) 其他可能面临的数据泄露、窃取、篡改、破坏/损毁、丢失、滥用、非法获取、非法利用、非法提供等安全威胁。

8 风险识别

8.1 通则

针对数据安全风险源和不合理处理数据风险源，通过对数据安全管理、数据处理活动、数据安全技术、个人信息保护等方面进行评估，发现可能存在的数据安全问题和风险隐患。具体实施时可按照以下步骤开展：

- a) 如果被评估方已开展过相关的测评工作，应先对已开展的测评工作结论进行分析。
- b) 针对被评估对象的特点，选择适用的评估内容进行评估，评估内容选择方法如下：
 - 1) 数据处理者均应识别数据处理活动（见 8.3）、数据安全组织（见 8.4）、数据安全技术（见 8.5）等风险情况。
 - 2) 个人信息处理者还应在 1) 的基础上，识别个人信息保护风险情况（见 8.6）。
- c) 被评估对象涉及数据出境的，应按照国家相关法规、国家标准要求进行数据出境相关评估、认证、备案等工作，若存在未按要求开展相关工作的，直接判定存在安全风险，并结合第 9 章进行风险分析与评价。
- d) 梳理各评估项的评估结果和发现的风险源，输出数据安全风险评估记录。

8.2 已开展测评工作结论分析

针对各个评估对象，从数据安全管理、数据处理活动、数据安全技术、个人信息保护等方面，通过多种评估手段识别可能存在的数据安全风险隐患。

被评估方应当按照国家法律法规、强制性国家标准等文件要求，通过有关检测评估。在开展风险评估时，应记录被评估方应开展的检测评估工作及实际开展情况，主要包括：

- a) 数据处理活动涉及应开展检测评估工作名称、要求来源等基本情况。
- b) 已开展检测评估工作有效性（指是否由有资质机构，按照正常程序开展）。
- c) 检测评估内容和结果，及检测评估工作开展情况。

已开展检测评估工作情况应由被评估方提供证明材料，评估人员可在分析评估结果真实性、有效性的基础上视情采纳。

若评估对象未实施或通过国家法律法规、强制性国家标准等文件要求的检测评估工作，如网络安全等级保护测评、云计算服务安全评估、互联网信息服务算法推荐安全评估、数据出境安全评估等，则判定存在未按要求开展检测评估工作的安全风险。

8.3 数据安全

应从数据安全管理制度、安全组织机构、分类分级管理、合作外包管理、安全威胁和应急管理、开发运维管理、云数据安全等方面识别数据安全风险管理。

注：应依据 TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》6.1 进行数据安全风险管理风险识别。

8.4 数据处理活动安全

应从以下方面识别数据处理活动安全风险：

- a) 数据收集安全风险识别：主要从数据收集合法性正当性、通过第三方收集数据安全、数据质量控制、数据收集方式、数据收集设备及环境安全等方面进行风险识别。

注 1：应依据 TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》6.2.1 进行数据收集安全风险识别。

- b) 数据存储安全风险识别：主要从数据存储适当性、逻辑存储安全、存储介质安全等方面进行风险识别。

注 2：应依据 TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》6.2.2 进行数据存储安全风险识别。

- c) 数据传输安全风险识别：主要从传输链路安全性、传输链路可靠性等方面进行风险识别。

注 3：应依据 TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》6.2.3 进行数据传输安全风险识别。

- d) 数据使用和加工安全风险识别：主要从数据使用和加工合法性、数据正当使用、数据导入导出、数据处理环境、数据使用和加工安全措施等方面进行风险识别。

注 4：应依据 TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》6.2.4 进行数据使用和加工安全风险识别。

- e) 数据提供安全风险识别：主要从数据提供合法正当必要性、数据提供管理、数据提供技术措施、数据接收方、数据转移安全、数据出境安全等方面进行风险识别。

注 5：应依据 TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》6.2.5 进行数据提供安全风险识别。

- f) 数据公开安全风险识别：主要从数据公开适当性、数据公开管理等方面进行风险识别。

注 6：应依据 TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》6.2.6 进行数据公开安全风险识别。

- g) 数据删除安全风险识别：主要从数据删除管理、存储介质销毁等方面进行风险识别。

注 7：应依据 TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》6.2.7 进行数据删除安全风险识别。

h) 其他数据处理活动安全风险识别：主要针对即时通信、快递物流、网上购物、网络支付、网络音视频、汽车、网络预约汽车服务等数据处理活动进行风险识别。

注 8：应依据 TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》6.2.8 进行数据安全风险识别。

8.5 数据安全技术

应从网络安全防护、身份鉴别与访问控制、检测预警、数据脱敏、数据防泄漏、数据接口安全、数据备份与恢复、安全审计等方面识别数据安全技术风险。

注：应依据 TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》6.3 进行数据安全技术风险识别。

8.6 个人信息保护

如被评估范围涉及个人信息处理，还应从个人信息处理基本原则、个人信息告知同意、个人信息处理、敏感个人信息处理、个人信息主体权利、个人信息安全义务、个人信息投诉举报、大型网络平台个人信息保护等方面识别个人信息保护风险。可视情采纳（部分）个人信息保护影响评估工作结论，也可依据 GB/T39335 识别个人信息保护风险。

注：应依据 TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》6.4 进行个人信息保护风险识别。

9 风险分析与评价

9.1 通则

在风险识别基础上，应按照 9.2.1 梳理得出数据安全风险源清单，分析可能存在的数据安全风险（常见风险可参考附录 A），应按照 9.2 和 9.3 进行风险分析和评价。其中，所有评估过程均应按照 9.2.1、9.2.2 梳理风险源清单、对风险归类，可结合实际需要，视情开展风险发生后的影响分析、风险发生可能性分析、风险评价。

结合数据资产和数据处理活动清单，针对每个评估对象的各个评估项评估情况，梳理存在的风险隐患，形成数据安全风险源清单。

注：应依据 TC260-PG-20231A《网络安全标准实践指南——网络数据安全风险评估实施指引》7.1 梳理数据安全为题清单，其所称问题清单与本文件所称风险源清单一致。

9.2 数据安全风险分析

9.2.1 风险分析

数据安全风险分析，主要从影响数据保密性、完整性、可用性和数据处理合理性角度分析各项风险源可能引发的数据安全风险，及风险危害程度和发生的可能性。

如多项数据安全问题的可能造成同样数据安全风险的，可以将其与其他问题合并进行风险分析。

9.2.2 风险归类

根据 9.1 形成的数据安全风险源清单，分析数据安全风险源可能引发的安全风险，按照风险类型对风险源归类，典型数据安全风险类别见附录 A。

9.2.3 风险危害程度分析

风险危害程度分析，主要分析数据的价值、重要性、规模、种类，以及数据处理目的、方式、范围等要素，综合评估数据安全风险一旦发生，对国家安全、经济运行、社会秩序、公共利益或者个人、组织合法权益造成的危害程度。风险危害程度从低到高可分为很低、低、中、高、很高 5 个级别。风险危害程度分析遵循就高从严、整体分析原则，如果该风险涉及多个数据资产，应进行累加判断，将涉及数据的风险按照最高危害等级判断。风险危害程度评价，主要考虑数据价值、数据重要性、风险源严重程度三个因素，分析方法如下：

- a) 数据价值主要从数据资产的经济效益、业务效益、投入成本计量等方面分析。
 - b) 数据重要性主要从数据分级角度衡量，数据级别越高代表数据重要性越高，数据安全级别可参考《信息安全技术 数据分类分级规则》确定。个人信息规模和数据敏感程度可以作为数据重要性判断的衡量因素。
 - c) 风险源严重程度，主要考虑风险源对数据处理者带来的危害程度。
- 数据安全风险危害程度的判断标准如表 1 所示。

表 1 数据安全风险危害程度等级参考

影响对象	危害程度	参考说明
国家安全	很高	直接危害国家安全重点领域，如政治安全。
	高	关系国家安全重点领域，或者对国土、军事、经济、文化、社会、科技、电磁空间、网络、生态、资源、核、海外利益、太空、极地、深海、生物、人工智能等任一领域国家安全造成严重威胁。
	中	对国土、军事、经济、文化、社会、科技、电磁空间、网络、生态、资源、核、海外利益、太空、极地、深海、生物、人工智能等任一领域国家安全造成威胁。
经济运行	很高	1.直接影响涉及国家安全的行业、支柱产业和高新技术产业中的重要骨干企业、提供重要公共产品的行业、重大基础设施和重要矿产资源行业等关系国民经济命脉行业的运行和发展。 2.关系国民经济命脉，严重危害对社会经济发展具有重大影响的行业领域、部门、企业、资源、区域等的生产运营和经济利益。 3.对一个或多个行业领域的发展态势、业务经营、技术进步、产业生态造成特别严重危害，如对核心业务造成重大损害，导致大面积业务中断、大量业务处理能力丧失等。 4.对一个或多个省（自治区、直辖市）的经济运行造成特别严重影响，例如导致大范围停工停产、大规模基础设施长时间中断运行等。
	高	1.直接影响宏观经济运行状况和发展趋势，如社会总供给和总需求、国民经济总值和增长速度、国民经济主要比例关系、物价总水平、劳动就业总水平与失业率、货币发行总规模与增长速度、进出口贸易总规模与变动等。 2.直接影响一个或多个地级市、行业内多个企业或大规模用户，对行业发展态势、技术进步和产业生态等造成严重影响，或者直接影响行业领域核心竞争力、核心业务运行、关键产业链、核心供应链等。
	中	1.对单个行业领域发展、业务经营、技术进步、产业生态等造成一般危害，如受影响的用户和企业数量较小、生产生活区域范围较小、持续时间较短、社会负面影响较小。 2.对单个行业领域的经济运行秩序造成一般危害，如市场准入、市场行为、市场结构、商品销售、交换关系、生产经营秩序等。
社会秩序	很高	1.关系重要民生，直接影响人民群众重要民生保障的事项、物资、工程或项目等。

影响对象	危害程度	参考说明
		2.直接导致特别重大突发事件、特别重大群体性事件、暴力恐怖活动等，引起一个或多个省（自治区、直辖市）大部分地区的社会恐慌，严重影响社会正常运行。
	高	1.直接导致重大突发事件、重大群体性事件等，影响一个或多个地市大部分地区的社会稳定。 2.严重影响人民群众的日常生活秩序。 3.严重影响各级政务部门履行公共管理和公共服务职能。 4.严重影响法治和社会伦理道德规范。
	中	1.对人民群众的日常生活秩序造成一般影响。 2.直接影响企事业单位、社会团体的生产秩序、经营秩序、教学科研秩序、医疗卫生秩序。 3.直接影响公共场所的活动秩序、公共交通秩序。
公共利益	很高	1.关系重大公共利益，导致一个或多个省（自治区、直辖市）大部分地区的社会公共资源供应长期、大面积瘫痪，大范围社会成员（如1000万人以上）无法使用公共设施、获取公开数据资源、接受公共服务。 2.可能导致特别重大网络安全和数据安全事件，或者导致特别重大事故级别的安全生产事故，对公共利益造成特别严重影响，社会负面影响大。 3.可能导致特别重大突发公共卫生事件（I级），造成社会公众健康特别严重损害的重大传染病疫情、群体性不明原因疾病、重大食物和职业中毒等严重影响公众健康的事件。
	高	1.直接危害公共健康和安全，如严重影响疫情防控、传染病的预防监控和治疗等。 2.可能导致重大突发公共卫生事件（II级），造成社会公众健康严重损害的重大传染病疫情、群体性不明原因疾病、重大食物和职业中毒等严重影响公众健康的事件。 3.导致一个或多个地市大部分地区的社会公共资源供应较长期中断，较大范围社会成员（如100万人以上）无法使用公共设施、获取公开数据资源、接受公共服务。
	中	对公共利益产生一般危害，影响小范围社会成员使用公共设施、获取公开数据资源、接受公共服务等。
组织权益	中	可能导致组织遭到监管部门严重处罚（包括取消经营资格、长期暂停相关业务等），或者影响重要/关键业务无法正常开展的情况，造成重大经济或技术损失，严重破坏机构声誉，企业面临破产。
	低	可能导致组织遭到监管部门处罚（包括一段时间内暂停经营资格或业务等），或者影响部分业务无法正常开展的情况，造成较大经济或技术损失，破坏机构声誉。
	很低	可能导致个别诉讼事件，或在某一时间造成部分业务中断，使组织的经济利益、声誉、技术等轻微受损。
个人权益	中	个人信息主体可能会遭受重大的、不可消除的、可能无法克服的影响，容易导致自然人的人格尊严受到侵害或者人身、财产安全受到危害。如遭受无法承担的债务、失去工作能力、导致长期的心理或生理疾病、导致死亡等。
	低	个人信息主体可能遭受较大影响，个人信息主体克服难度高，消除影响代价较大。如遭受诈骗、资金被盗用、被银行列入黑名单、信用评分受损、名誉受损、造成歧视、被解雇、被法院传唤、健康状况恶化等。
	很低	个人信息主体可能会遭受困扰，但尚可以克服。如付出额外成本、无法使用应提供的服务、造成误解、产生害怕和紧张的情绪、导致较小的生理疾病等。
注：数据处理者可根据数据对自身的价值、重要性，结合风险源严重程度，将仅影响组织权益、个人权益等		

影响对象	危害程度	参考说明
的风险危害程度自行定为或调整为“很高”“高”等级别，及时进行风险处置。		

9.2.4 风险发生可能性分析

风险发生可能性分析，主要考虑风险源发生频率、安全措施有效性和完备性、风险源关联性等因素。分析方法如下：

- a) 风险源发生频率，可从被评估对象发生相关数据安全事件的次数及频率、同行业或业务模式相似的单位发生相关数据安全事件的次数及频率、相似数据安全事件发生次数及频率、轻微安全问题累计发生次数等方面，综合分析同类风险源发生可能性。一般风险源或安全事件发生频率越高，风险发生可能性越高。
- b) 安全措施有效性、完备性，主要通过识别数据安全措施应对风险源的有效性、全面性等。核心数据、重要数据及相关数据处理活动，需采取更严格的安全防护措施才能降低风险发生可能性。
- c) 风险源关联性，主要通过风险源清单关联分析，发现多个风险源组合后可能引发数据安全风险，则将其与其他风险源合并分析，综合判断风险发生可能性。

在综合分析风险源发生频率、安全措施有效性和完备性、风险源关联性的基础上，将数据安全风险发生的可能性从低到高分低、中、高 3 个级别，如表 2 所示。等级越高代表措施完备性、有效性越低，风险越可能发生。如需进行定量分析，可参考附录 B.2。

表 2 风险发生可能性等级参考

等级	风险发生可能性描述
高	涉及违法违规行为、缺少数据安全措施或安全措施有效性较弱，被评估对象或同类组织多次高频发生相关风险源，或容易与其他风险源结合引发风险，风险隐患发生可能性高（例如出现频率高、在大多数情况下几乎不可避免、可以证实经常发生过）。
中	有一定数据安全措施，但有效性不足，被评估对象或同类组织发生相关风险源，或有一定概率与其他风险源结合引发风险，风险隐患发生可能性一般（例如出现频率中等，在某种情况下可能发生，或被证实曾经发生）。
低	数据安全措施比较到位、完备，被评估对象或同类组织很少发生相关风险源，或很难与其他风险源结合引发风险，风险隐患发生可能性低（例如几乎不可能发生，或仅可能在非常罕见和例外的情况下发生）。

9.3 数据安全风险评价

可基于实际情况，视情对数据安全风险进行评价。风险评价一般结合评估对象实际情况，基于 9.2.3 和 9.2.4 的分析结果，综合风险危害程度及风险发生可能性对安全风险进行综合评价。

数据安全风险评价结果包括：

- a) 重大安全风险：一般指可能直接影响国家安全的数据安全风险。
- b) 高安全风险：一般指可能直接影响经济运行、社会稳定、公共健康安全，以及较为广泛的公众权益，或对国家安全造成间接影响的数据安全风险。
- c) 中安全风险：一般指可能直接对企业合法权益造成较为严重的影响，或直接对自然人的人格尊严受到严重侵害或者人身、财产安全受到严重危害，或对经济运行、社会稳定、公众利益造成较为严重间接影响的数据安全风险。
- d) 低安全风险：一般指可能直接对企业合法权益造成一般影响，或直接对自然人的人格尊严受到侵害或者人身、财产安全受到危害，或对社会、公众权益有一定或较小影响的数据安全风险。
- e) 轻微安全风险：一般指可能直接对企业合法权益造成一般或较小影响，或对自然人人格尊严、人身安全、财产安全不造成侵害或仅产生较轻微的危害，或对小范围的组织或公民个体权益造

成影响的数据安全风险。

数据处理者可根据自身情况，将仅影响组织权益、个人权益等的风险自行定为或调整为“重大”“高”等级别，及时进行风险处置。本文件提出了定性和定量评价风险的方法，表 3 提供了一种风险等级定性评价方法，如需获得风险定量评价结果，可参考附录 B.3 进行风险评价。

表 3 数据安全风险评价矩阵

可能性 \ 危害程度	很高	高	中	低	很低
	很高	高	中	低	很低
高	重大安全风险	重大安全风险	中安全风险	低安全风险	轻微安全风险
中	重大安全风险	高安全风险	低安全风险	低安全风险	轻微安全风险
低	中安全风险	中安全风险	轻微安全风险	轻微安全风险	轻微安全风险

9.4 数据安全风险清单

针对各项数据安全风险完成风险评价后，整理各项风险评估结果，在 9.1 的初步风险清单基础上形成数据安全风险清单（如表 4 所示），列出各项风险的风险等级、危害程度、发生可能性等。

表 4 数据安全风险清单

序号	风险类型	风险源	风险源描述	风险危害程度	风险发生的可能性	风险等级	涉及的数据及类型	涉及的数据处理活动	评估情况描述

10 评估总结

10.1 编制评估报告

根据评估情况，评估团队编制数据安全风险评估报告（报告模板参见附录 C）。评估报告应准确、清晰地描述评估活动的主要内容（并附必要的证据或记录），提出可操作性的整改措施对策建议。风险评估报告的内容包括：

- a) 评估概述，包括评估目的及依据，评估对象和范围，评估结论等。
- b) 评估工作情况，包括评估人员、评估时间安排、评估工具和环境情况等。
- c) 信息调研情况，包括数据处理者、业务和信息系统、数据资产、数据处理活动、安全措施等情况，形成的数据资产清单、数据处理活动清单、数据流图等文件可视情放在报告正文或附件中。
- d) 数据安全风险识别，包括数据安全治理、数据处理活动、数据安全技术、个人信息保护等方面识别的风险源情况。
- e) 风险分析与评价，对数据安全问题可能带来的安全风险进行综合分析，视情对风险进行评价。
- f) 整改建议，针对发现的数据安全问题或风险，提出整改措施或风险处置建议。
- g) 数据安全风险源清单，列出完整的数据安全风险源清单，并附上关键记录和证据，若证据无法在附录中完整列出，应列出证据关键信息和序号，在提交评估报告时作为附件提交。
- h) 涉及重要数据、个人信息、核心数据的，应当详细列出处理的数据种类、数量（不包括数据内容本身），开展数据处理活动的情况，面临的数据安全风险及其应对措施等。
- i) 委托第三方机构开展评估或检查评估的，评估报告应由评估组长、审核人签字，并加盖评估机构公章。

10.2 风险处置建议

评估人员结合实际情况，对发现的数据安全风险提出处置建议，酌情指导数据处理者整改。被评估方应制定数据安全风险处置方案，限期完成整改，无法及时完成整改的，应采取临时安全措施，防止数据安全事件发生。常见数据安全风险处置措施包括但不限于以下选项：

- a) 停止收集某些类型的数据。
- b) 预处理阶段对某些类型数据进行销毁。
- c) 缩小处理范围。
- d) 缩短存储期限。
- e) 采取额外的技术措施。
- f) 加强对应数据处理活动岗位人员培训。
- g) 匿名化、去标识化。
- h) 完善管理制度。
- i) 采用其他数据处理技术。
- j) 补充签署协议（针对数据转移）。
- k) 修订隐私条款。

10.3 残余风险分析

评估人员根据数据处理者决定的风险处置措施，结合风险识别和评估方法，预判措施有效性和残余风险，形成记录。被评估方完成整改后，评估方可视情开展数据安全风险复评工作，复评时可重点分析风险处置后的残余风险，以及采取额外控制措施可能导致的次生风险等。

附 录 A
(规范性)
典型数据安全风险类别

本附录给出了常见数据安全风险类别，如数据泄露风险、数据篡改风险、数据破坏风险、数据丢失风险等，如表 A.1 所示。

表 A.1 典型数据安全风险类别示例

序号	风险类别	描述
1	数据泄露风险	由于数据窃取、爬取、脱库、撞库等安全威胁，或者缺乏有效的安全措施、人员操作失误或有意盗取等，导致数据泄露、恶意窃取、未授权访问等影响数据保密性的风险。
2	数据篡改风险	由于数据注入、中间人攻击等安全威胁，或者缺乏有效的安全措施、人员有意或无意操作等，导致数据被未授权篡改等影响数据完整性的风险。
3	数据破坏风险	由于拒绝服务攻击、自然灾害、嵌入恶意代码、数据污染、设备故障等安全威胁，或者缺乏有效的安全措施、人员有意或无意操作等，导致数据被破坏、毁损、数据质量下降等影响数据可用性的风险。
4	数据丢失风险	由于数据过载、软硬件故障、备份失效、链路过载等问题，或者缺乏有效的安全措施、人员有意或无意操作等，导致数据丢失、难以恢复等安全风险。
5	数据滥用风险	由于缺乏授权访问控制、权限管控等有效的安全管控措施、人员有意或无意操作等，导致数据被未授权或超出授权范围使用、加工的风险。
6	数据伪造风险	由于数据源欺骗、深度伪造等安全威胁，或者缺乏有效的安全措施、人员有意或无意操作等，导致数据或数据源被伪造、数据主体被仿冒等安全风险。
7	违法违规获取数据	违反法律、行政法规等有关规定，非法或违规获取、收集数据的风险。
8	违法违规出售数据	违反法律、行政法规等有关规定，非法或违规向他人出售、交易数据的风险。
9	违法违规保存数据	违反法律、行政法规等有关规定，非法或违规留存数据的风险，如逾期留存、违规境外存储等。
10	违法违规利用数据	违反法律、行政法规等有关规定，非法或违规使用、加工、委托处理数据的风险。
11	违法违规提供数据	违反法律、行政法规等有关规定，非法或违规向他人提供、共享、交换、转移数据的风险。
12	违法违规公开数据	违反法律、行政法规等有关规定，非法或违规公开数据的风险。
13	违法违规购买数据	违反法律、行政法规等有关规定，非法或违规购买、收受数据的风险。
14	违法违规出境数据	违反法律、行政法规等有关规定，非法或违规向境外提供数据的风险。
15	超范围处理数据	数据处理活动违反必要性原则，超范围或过度收集使用个人信息或重要数据的风险。
16	数据处理缺乏正当性	违反正当性原则，数据处理活动缺乏明确、合理的处理目的。
17	未有效保障个人信息主体权利	由于未采取有效的个人信息保护措施、人员操作或外部威胁等，导致未能有效保障个人信息主体的知情权、决定权、限制或者拒绝个人信息处理等个人信息主体合法权利。
18	App 违法违规收集使用个人信息	App 违反个人信息监管政策或标准规范，存在违法违规收集使用个人信息行为的风险。
19	数据处理缺乏公平公正	由于缺乏安全管控措施、人员有意或无意操作等，导致数据处理违反公平公正、诚实守信原则，侵犯其他组织或个人合法权益的风险。

序号	风险类别	描述
20	数据处理抵赖风险	由于外部攻击威胁、缺乏有效安全管控措施、人员有意或无意操作等，导致处理者或第三方否认数据处理行为或绕过数据安全措施等风险。
21	数据不可控风险	由于第三方数据安全能力不足、缺乏有效的第三方管控措施、合同协议缺失、外包人员操作等，导致委托处理或合作的第三方违反法律法规或合同协议约定处理数据，造成第三方超范围处理数据、逾期留存数据、违规再转移等数据不可控风险。
22	数据推断风险	由于未考虑数据之间的关联关系，导致从公开数据可推断出核心数据、重要数据、未公开的个人数据等，包括但不限于面向人工智能模型的推理攻击、面向基础设施的跨域推断攻击等
23	其他风险	其他可能影响国家安全、公共利益或组织、个人合法权益的数据安全风险。

附录 B
(规范性)

数据安全风险量化分析与评价方法

B.1 数据安全风险危害程度量化分析方法

结合 9.2.3 给出的数据安全风险危害程度定性分析方法，表 B.1 按照百分制给出数据安全风险危害程度量化分析方法，结合实际情况，根据得分区间给出风险危害程度得分值，得分越高代表风险危害程度越高。

表 B.1 数据安全风险危害程度等级参考

等级	得分
很高	[80%, 100%]
高	[60% 80%)
中	[40%, 60%)
低	[20%, 40%)
很低	[0%, 20%)

B.2 数据安全风险发生可能性量化分析方法

结合 9.2.4 给出的数据安全风险发生可能性定性分析方法，表 B.2 按照百分比给出数据安全风险发生可能性量化分析方法，结合实际情况，根据得分区间给出风险发生可能性得分值，得分越高代表风险发生可能性越高。

表 B.2 数据安全风险发生可能性等级参考

等级	得分
高	[75% 100%]
中	[30%, 75%)
低	[0%, 30%)

B.3 数据安全风险量化评价方法

结合 9.3 给出的数据安全风险评价方法，本节提出数据安全风险量化评价方法，结合实际情况，根据 B.1 和 B.2 给出的量化结果计算风险分值，得分越高代表风险等级越高。计算公式如下：

$R_i = \sigma_i \times V_i$ ，其中 R_i 为第 i 个数据的风险评价分值， σ_i 为第 i 个数据危害程度赋值； V_i 为第 i 个数据的风险发生可能性赋值。

附 录 C
(资料性)
数据安全风险评估报告模板

C.1 数据安全风险评估报告封面

数据安全风险评估报告 评估单位（盖章）： 报告时间： 年 月 日

C.2 数据安全风险评估报告基本信息表

被评估方			
单位名称		统一社会信用代码	
单位地址		邮政编码	

评估对象				
联系人	姓名		职务/职称	
	联系方式		所属部门	
真实性 声明	被评估方承诺： 提供的材料准确、真实、合法、有效，并愿为此承担有关法律责任。			
数据安全负 责人				
评估队伍单位信息				
单位名称				
单位地址			邮政编码	
联系人	姓名		联系方式	
审核批准	评估组长		日期	
	审核人		日期	

C.3 数据安全风险评估报告主要内容

一、评估概述

1.1 评估目的

1.2 评估依据

1.3 评估对象和范围

说明评估对象的选择原则，描述评估对象和评估范围。

1.4 评估结论概要

说明数据和数据处理活动的概要情况，评估结果概要。

二、评估工作开展情况

2.1 评估人员情况

说明评估工作组织和评估团队人员情况，被评估方参与人员情况。

2.2 评估时间安排情况

说明本次评估工作的时间进度安排，描述各阶段完成的任务、工作成果和时间节点等内容。

2.3 评估工具和环境情况

说明使用的评估工具，接入的网络或系统环境、技术测试内容等情况。

三、信息调研情况

按照本文件第 7 章内容说明信息调研情况。

3.1 数据处理者基本情况

说明数据处理者的机构实体基本情况。

3.2 业务和信息系统情况

说明主营业务、信息系统、App 和网络拓扑等情况。

3.3 数据资产情况

说明数据资产、数据分类分级，涉及个人信息、重要数据、核心数据目录等情况。

3.4 数据处理活动情况

说明数据收集、数据存储、数据使用、数据加工、数据传输、数据提供、数据公开、数据删除、数据出境情况。
针对评估对象结合实际情况画出数据流转图。

3.5 安全措施情况

说明已开展的安全测评认证和核实情况，数据安全管理机构、人员及制度情况，网络和数据安全主要措施。

四、数据安全风险识别

按照本指南第 6 章内容，从数据安全、处理活动、技术、个人信息处理等方面，说明各评估对象的风险隐患或安全问题，如有必要可附上关键证据材料。

4.1 数据安全风险管理识别

4.2 数据处理活动风险识别

4.3 数据安全技术风险识别

4.4 个人信息处理风险识别

五、风险分析与评价

按照本指南第 7 章，针对本报告第 4 章发现的问题隐患，参考附录 A 分析数据安全风险，视情进行风险评价，提出整改建议。具体风险分析和评价方法，可参考数据安全风险评估方法国家标准。

5.1 风险分析

5.2 风险评价（可选）

5.3 整改建议

附录 XXXX

附录可给出完整的数据安全风险源清单，根据实际需要提供评估底稿，或者补充相应的证据材料等。

C.3 数据安全风险评估报告声明模板

声 明

【填写说明：声明是评估机构对评估报告的有效性前提、评估结论的适用范围以及使用方式等有关事项的陈述，评估机构可参考以下建议书写内容编制。】

本报告是[被评估方名称]的网络数据安全风险评估报告。

本报告评估结论的有效性建立在被评估方提供相关证据的真实性基础之上。

本报告中给出的评估结论仅对被评估方当时的安全状态有效。当评估工作完成后，由于被评估方发生变更而涉及到的数据或数据处理活动本报告不再适用。

在任何情况下，若需引用本报告中的评估结果或结论都应保持其原有的意义，不得对相关内容擅自进行增加、修改和伪造或掩盖事实。

单位名称（加盖单位公章）

年 月 日

参 考 文 献

- [1]GB/T 37988—2019 信息安全技术 数据安全能力成熟度模型
 - [2]GB/T 35273—2020 信息安全技术 个人信息安全规范
 - [3]GB/T 39335—2020 信息安全技术 个人信息安全影响评估指南
 - [4]GB/T 20984—2022 信息安全技术 信息安全风险评估方法
 - [5]JR/T 0223—2021 金融数据安全 数据生命周期安全规范
 - [6]YD/T 3801—2020 电信网和互联网数据安全风险评估实施方法
 - [7]中华人民共和国数据安全法（2021年6月10日中华人民共和国第十三届全国人民代表大会常务委员会第二十九次会议通过）
 - [8]中华人民共和国个人信息保护法（2021年8月20日中华人民共和国第十三届全国人民代表大会常务委员会第三十次会议通过）
 - [9]中华人民共和国网络安全法（2016年11月7日中华人民共和国第十二届全国人民代表大会常务委员会第二十四次会议通过）
 - [10]《App违法违规收集使用个人信息认定方法》（2019年11月28日国家互联网信息办公室秘书局、工业和信息化部办公厅、公安部办公厅、市场监管总局办公厅联合印发）
 - [11]《常见类型移动互联网应用程序必要个人信息范围规定》（2021年3月12日国家互联网信息办公室秘书局、工业和信息化部办公厅、公安部办公厅、市场监管总局办公厅联合印发）
-